

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA5112

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Comparative Analysis

Code of Conduct:

I G. Srivalli (192365014) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

G. Srivalli

Annexure A
Comparative Analysis

- Apply **SSL/TLS and IPsec protocols** to a secure communication scenario and determine which provides better security for web-based and network-layer protection.
- Design a secure email system by comparing **end-to-end encryption and gateway-based encryption**, and justify the most suitable approach for enterprise use.
- Apply **HMAC and Digital Signature techniques** to a data transmission scenario and analyze which method provides better authentication and integrity.
- Create a **spam detection system** by comparing supervised learning and unsupervised learning approaches, and evaluate their effectiveness in real-world email filtering.
- Design a secure communication framework by comparing **AES and RSA encryption techniques**, and determine their roles in achieving confidentiality and efficiency.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Scope of Items	20%	Selects highly relevant items with clear scope and justification	Selects appropriate items with minor gaps	Selection is limited or partially relevant	Items are unclear or not relevant
Comparison Depth	25%	Provides detailed and comprehensive comparison across multiple aspects	Provides adequate comparison with some depth	Limited comparison with few aspects	Very minimal or no comparison
Use of Evidence	20%	Supports comparison with accurate data, examples, or references	Uses some supporting evidence with minor gaps	Limited or weak supporting evidence	No supporting evidence provided
Critical Thinking	20%	Demonstrates strong critical thinking with clear interpretation and reasoning	Shows reasonable interpretation with minor gaps	Basic interpretation; lacks depth	No meaningful interpretation
Clarity of Presentation	15%	Well-organized, clear, and logically structured presentation	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

Question 1: Comparative Analysis of SSL/TLS and IPsec Protocols

Scenario: Apply SSL/TLS and IPsec protocols to a secure communication scenario and determine which provides better security for web-based and network-layer protection.

1. Overview of Protocols:

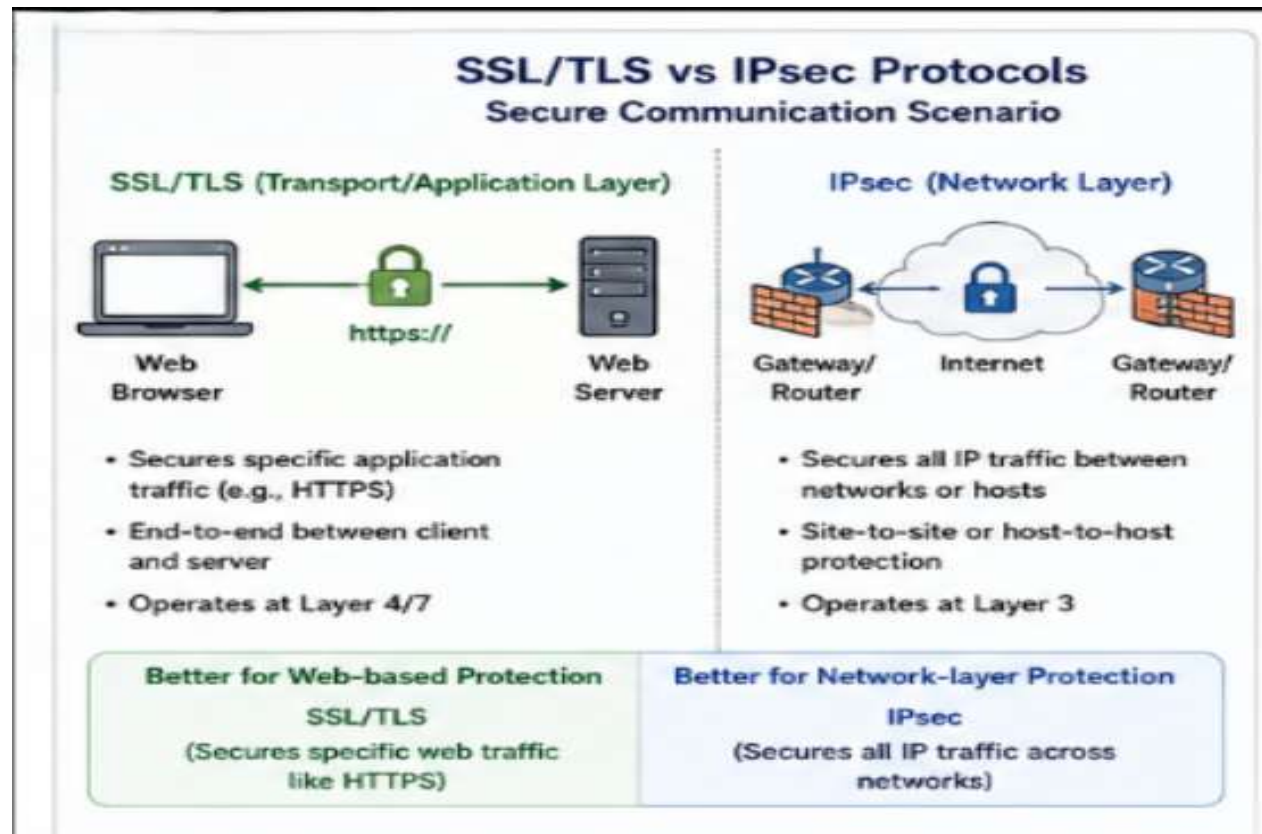
- **SSL/TLS (Transport Layer Security):** Operates primarily at the Transport/Application layer (Layer 4/7 of OSI). It secures end-to-end socket connections between specific client applications (e.g., a web browser) and server applications (e.g., an HTTPS web server).
- **IPsec (Internet Protocol Security):** Operates at the Network Layer (Layer 3 of OSI). It secures all IP traffic passing between two endpoints, networks, or gateways regardless of the underlying application.

2. Technical Comparison Matrix:

Comparison Parameter	SSL/TLS (Transport/Application Layer)	IPsec (Network Layer)
OSI Layer	Layer 4 (Transport) / Layer 7 (Application)	Layer 3 (Network Layer)
Operating Modes	Handshake, Record, Alert, Change Cipher Spec Protocols	Transport Mode (payload encrypted) & Tunnel Mode (entire packet encrypted)
Key Management	TLS Handshake Protocol using PKI / X.509 Certificates	Internet Key Exchange (IKEv1 / IKEv2) using ISAKMP
Sub-Protocols	TLS Record Protocol, TLS Handshake Protocol	Authentication Header (AH) & Encapsulating Security Payload (ESP)
Application Transparency	Requires application-level support (e.g., HTTPS, SMTPS).	Completely transparent to user applications.
Client Configuration	Zero configuration (built into standard browsers).	Requires dedicated VPN client software or specialized routers/firewalls.
Granularity	Fine-grained (per process, session, or web page connection).	Coarse-grained (all host-to-host or network-to-network traffic).

3. Architecture & Protocol Diagrams:

SSL/TLS Protocol Stack & IPsec Protocol Architecture Diagram:



4. Evaluation & Conclusion:

- **For Web-Based Security: SSL/TLS** is decisively superior. It provides seamless, clientless web security directly within standard browsers via public key infrastructure (PKI) certificates, enabling fine-grained control over individual web sessions.
- **For Network-Layer Protection: IPsec** is superior. In Tunnel Mode, IPsec secures all host-to-host or site-to-site communication, obfuscating internal IP addresses and protecting non-TCP/UDP application protocols without requiring application modification.

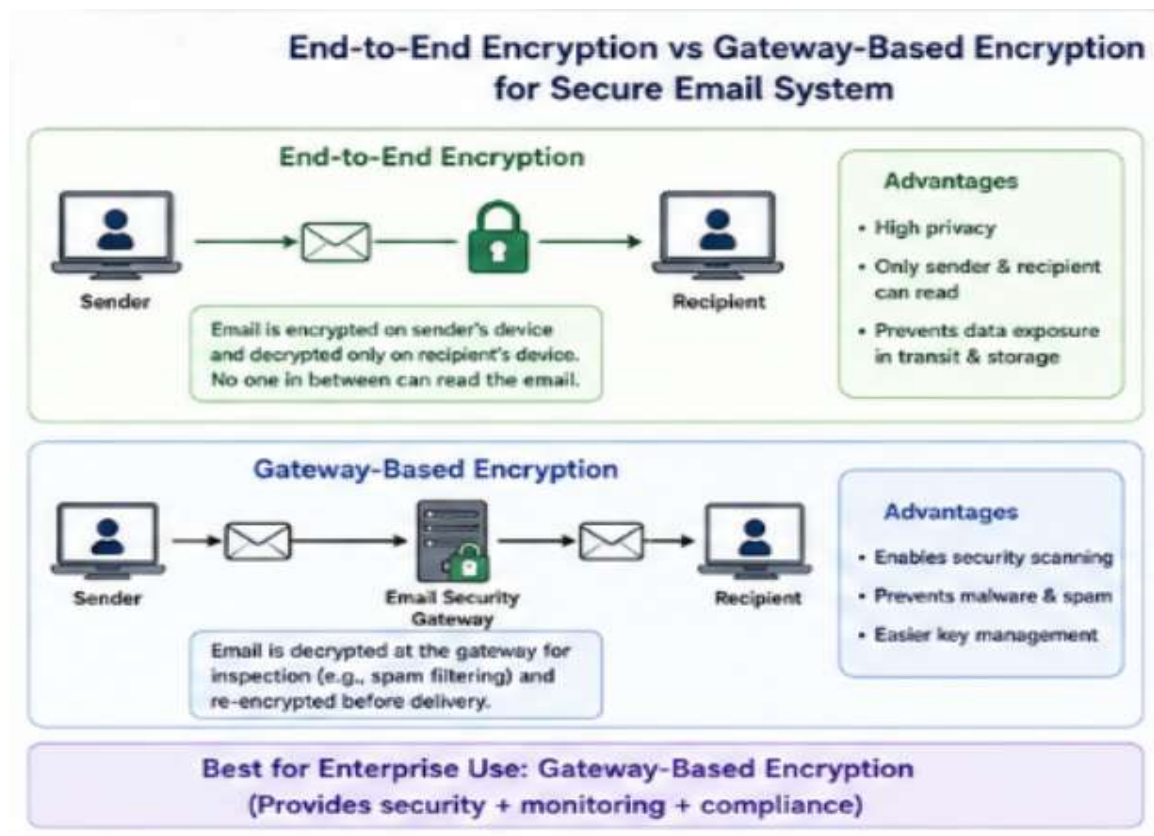
Question 2: Design of a Secure Email System (End-to-End vs. Gateway-Based Encryption)

Scenario: Design a secure email system by comparing end-to-end encryption and gateway-based encryption, and justify the most suitable approach for enterprise use.

1. Architecture Breakdown:

- **End-to-End Encryption (E2EE):** Messages are encrypted directly on the sender's client device (using protocols like PGP/GPG or S/MIME) and decrypted only on the recipient's client device. Intermediate mail servers (MTA) see only encrypted data.
- **Gateway-Based Encryption (EG):** Messages travel unencrypted (or encrypted over TLS) from the user client to an Enterprise Mail Gateway. The gateway performs policy enforcement, content filtering, and encrypts the message before sending it over the Internet to a partner gateway or recipient.

2. High-Level System Architecture Diagram:



3. Detailed Comparison Matrix:

Security & Operational Parameter	End-to-End Encryption (S/MIME / PGP)	Gateway-Based Encryption
Key Management	Complex: Users manage private keys or local certificates. High risk of key loss.	Centralized: Managed automatically by enterprise servers/HSMs. Seamless to users.
Data-in-Transit Protection	Complete: Protected across every hop, including intermediate mail servers.	Partial: Protected over external networks; internal network relies on local TLS.
DLP & Malware Scanning	Impossible at Server Level: Gateways cannot scan encrypted payloads for leaks or viruses.	Full Capability: Centralized inspection occurs prior to outbound encryption.
Compliance & Archiving	Difficult: Requires escrowing private keys to search archived emails for audits.	Easy: Centralized logging, indexing, and compliance scanning prior to encryption.
User Experience	Steep Learning Curve: Requires manual certificate setup or key exchanges.	Transparent: Users send standard emails; policy engines automatically encrypt based on rules.

4. Enterprise Justification & Hybrid Recommendation:

For standard enterprise deployment, Gateway-Based Encryption combined with TLS enforced transport is the most suitable approach. It guarantees enterprise policy enforcement, Data Loss Prevention (DLP) compliance, centralized key management, and automated anti-malware scanning without overburdening non-technical employees.

Hybrid Recommendation for High-Security Enterprise Domains: Implement Gateway Encryption as default for all general corporate communications, while providing dedicated S/MIME or PGP software for executive and sensitive research departments that require true zero-trust end-to-end confidentiality.

Question 3: HMAC vs. Digital Signature Analysis for Data Transmission

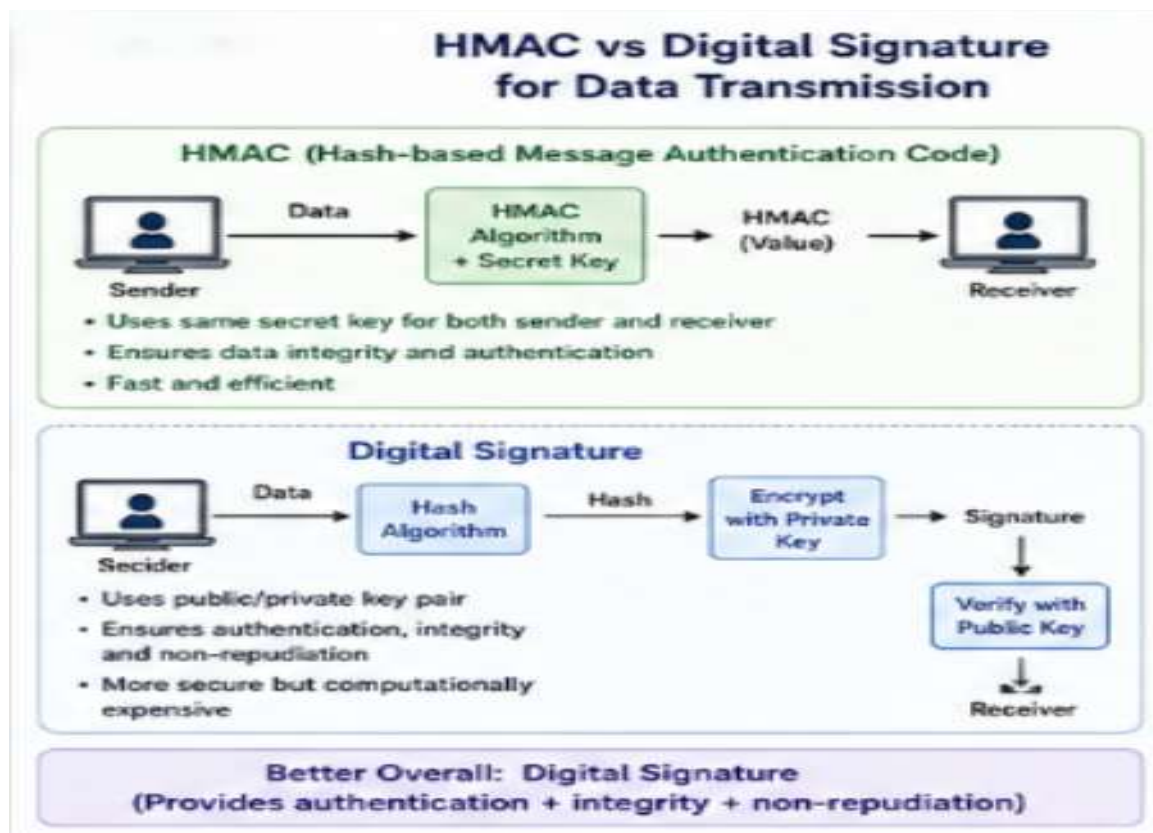
Scenario: Apply HMAC and Digital Signature techniques to a data transmission scenario and analyze which method provides better authentication and integrity.

1. Technical Mechanism:

- **HMAC (Hash-based Message Authentication Code):** Combines a cryptographic hash function (e.g., SHA-256) with a pre-shared secret symmetric key. HMAC provides integrity and data origin authentication, but only between parties sharing the key.
- **Digital Signature:** Combines an asymmetric cryptographic algorithm (e.g., RSA, ECDSA) with a cryptographic hash. The sender hashes the message and encrypts the hash with their *Private Key*. Anyone with the sender's *Public Key* can verify it.

2. Architectural Process Diagrams:

HMAC Generation & Digital Signature Generation & Verification Flow:



3. Comparison Analysis Matrix:

Feature / Criterion	HMAC (Symmetric Approach)	Digital Signature (Asymmetric Approach)
Cryptographic Primitives	Hash Functions (SHA-256, SHA-3) + Shared Symmetric Key	Asymmetric Key Pairs (RSA, ECDSA) + Hash Functions
Computational Overhead	Extremely Low: Uses fast symmetric hashing operations.	High: Requires complex modular exponentiation or elliptic curve math.
Data Integrity	Yes: Any modification in transit corrupts the hash value.	Yes: Any modification invalidates signature verification.
Data Origin Authentication	Group Authentication: Proves sender knows shared key.	Individual Authentication: Uniquely identifies specific key owner.
Non-Repudiation	No: Either party possessing the shared key could have created the HMAC.	Yes: Only the holder of the private key could generate the valid signature.
Key Management Scalability	Poor: $O(N^2)$ secret keys required for pairwise communication.	Excellent: $O(N)$ key pairs managed via Public Key Infrastructure (PKI).

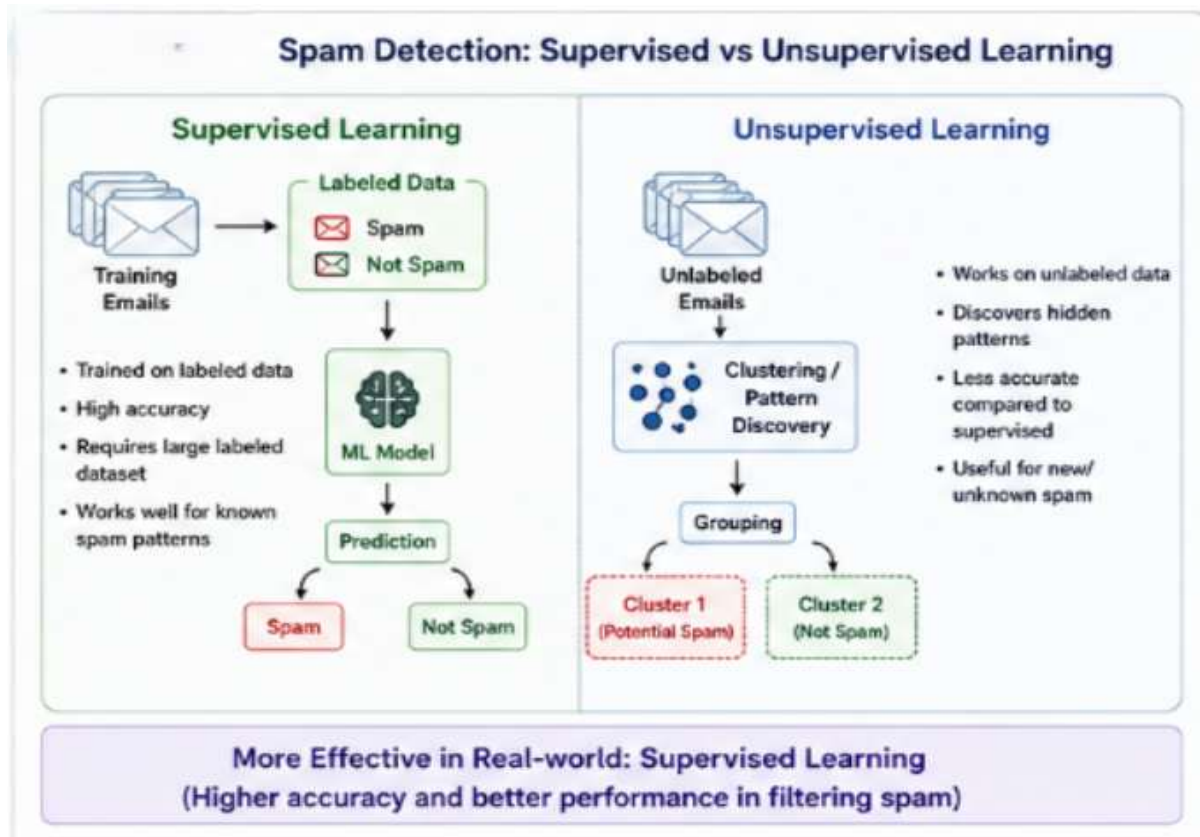
4. Analytical Evaluation & Best Usage:

- **Performance & High-Throughput Scenarios:** HMAC is vastly superior due to low computational requirements, making it ideal for API authentication (e.g., OAuth headers), TLS record layer integrity, and real-time streaming services.
- **Legal Proof & Non-Repudiation Scenarios:** Digital Signatures are mandatory when non-repudiation is required (e.g., financial transfers, contract signing, legal document verification, and email signing via S/MIME).

Question 4: Spam Detection System: Supervised vs. Unsupervised Learning

Scenario: Create a spam detection system by comparing supervised learning and unsupervised learning approaches, and evaluate their effectiveness in real-world email filtering.

1. Machine Learning System Architecture:



2. Algorithmic Approach Comparison:

- **Supervised Learning:** Uses pre-labeled datasets (emails tagged explicitly as "Spam" or "Ham"). Popular algorithms include Naive Bayes, Support Vector Machines (SVM), and Random Forests.
- **Unsupervised Learning:** Works on unlabeled email corpora to identify inherent patterns, structural clusters, or statistical anomalies. Popular algorithms include K-Means Clustering, DBSCAN, and Isolation Forests.

3. Detailed Performance Matrix:

Evaluation Dimension	Supervised Learning (e.g., Naive Bayes, SVM)	Unsupervised Learning (e.g., K-Means, Isolation Forest)

Training Requirement	Requires massive, accurately labeled datasets.	Requires no prior labeling; trains directly on raw data.
Detection Accuracy (Known Attacks)	Exceptionally High (Precision & Recall > 98% on familiar patterns).	Moderate to Low (High risk of false positives).
Zero-Day / New Variant Adaptation	Poor until retrained on new labeled instances.	Strong at detecting statistical anomalies and brand new campaign structures.
False Positive Rate (FPR)	Very Low: Highly accurate at preserving legitimate emails.	Relatively High: Normal business communication anomalies may be flagged.
Computational Complexity	Fast inference phase; training cost dependent on dataset size.	Computationally expensive iterative distance clustering (e.g., $O(K \cdot N \cdot D)$).

4. Real-World Hybrid Implementation Framework:

In enterprise-grade mail transfer agents (MTAs) such as Google Gmail or Microsoft Defender for Office 365, relying solely on one approach is insufficient. A Hybrid Engine Architecture is employed:

1. **Primary Filtering (Supervised Layer):** Filters 95%+ of incoming traffic against known spam signatures, phishing templates, and malicious URLs using Naive Bayes, Deep Learning, and SVM models.
2. **Secondary Anomaly Detection (Unsupervised Layer):** Analyzes remaining traffic for unusual sending behavior, novel text clusters, or anomalous domain reputations to detect zero-day phishing outbreaks.

Question 5: Secure Communication Framework: AES vs. RSA Encryption

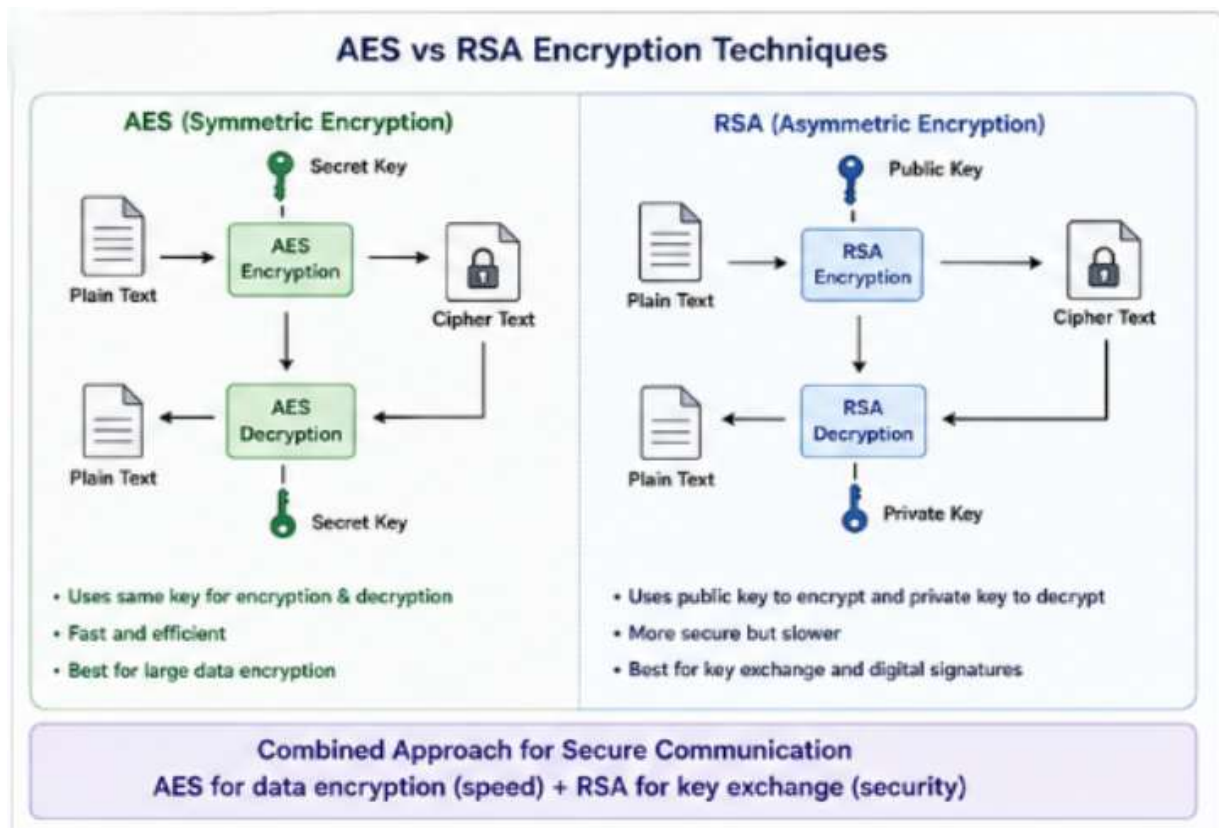
Scenario: Design a secure communication framework by comparing AES and RSA encryption techniques, and determine their roles in achieving confidentiality and efficiency.

1. Cryptographic Mechanics & Comparison Matrix:

Cryptographic Parameter	AES (Advanced Encryption Standard)	RSA (Rivest-Shamir-Adleman)
Cryptographic Type	Symmetric Key Encryption (Symmetric Block Cipher)	Asymmetric Key Encryption (Public-Key Cryptography)
Key Sizes	128, 192, or 256 bits	2048, 3072, or 4096 bits
Mathematical Foundation	Substitution-Permutation Network (Galois Field $GF(2^8)$)	Prime Factorization Hardness Problem ($N = p \cdot q$)
Computational Speed	Extremely Fast (Hardware accelerated via Intel AES-NI).	Slow (Heavy modular exponentiation mathematics).
Data Size Limit	Unlimited (via Block Modes like GCM, CBC).	Limited to key length size minus padding (e.g., < 245 bytes for RSA-2048).
Primary Security Role	Bulk Data Confidentiality (Encrypting payloads/files).	Key Exchange, Digital Certificates, Session Authentication.

2. Hybrid Encryption System Framework Architecture:

To achieve both mathematical security and maximum computational performance, modern communication frameworks (such as HTTPS/TLS and PGP) combine AES and RSA into a Hybrid Cryptosystem Architecture.



3. Summary of Roles in Secure Frameworks:

- **Role of RSA (Asymmetric Phase):** Secures the initial handshake phase. It authenticates the endpoints via digital certificates and securely exchanges/establishes the temporary AES symmetric session key without requiring a pre-shared secret over insecure networks.
- **Role of AES (Symmetric Phase):** Handles bulk data transmission. Once the session key is established, all high-volume application payload data is encrypted using AES-GCM or AES-CBC, providing high throughput, sub-millisecond encryption speeds, and authenticated encryption data integrity.